

❑ SOC Analyst Handbook for Freshers

Your Step-by-Step Guide to Starting a Cybersecurity Career



Author: Ishwar Bundeale

Year: 2025

☐ SOC Analyst Handbook for Freshers

Chapter 1: Introduction to Cybersecurity & SOC

1.1 What is Cybersecurity?

- Cybersecurity means **protecting computer systems, networks, and data** from attacks, damage, or unauthorized access.
- It is like putting **locks and security guards** on your digital world.

☐ Example: Just like you lock your house doors to keep thieves out, cybersecurity locks digital systems to keep hackers out.

1.2 Why Organizations Need a SOC

- Companies store **sensitive data** (customer info, financial details, trade secrets).
- Hackers are always trying to steal or damage this data.
- A **Security Operations Center (SOC)** is like a **command center** where security experts watch over everything 24/7.

☐ Think of SOC as a **digital CCTV control room** where analysts monitor for suspicious activity and respond quickly.

1.3 What is a SOC?

- A **SOC** is a dedicated team + technology setup that continuously monitors, detects, investigates, and responds to cyber threats.
- SOC is the **heart of cybersecurity defense** in an organization.

1.4 SOC Roles and Hierarchy

- **L1 Analyst (Fresher/Entry-level):** First to see alerts, does triage (decides if it's important or false alarm).
- **L2 Analyst:** Deep investigation, hunts threats, escalates serious cases.
- **L3 Analyst/Incident Responder:** Handles major incidents, advanced forensics.
- **SOC Manager / Incident Manager:** Leads the team, manages reports, compliance, and business communication.

1.5 A Day in the Life of a SOC Analyst

- **Start of shift:** Check dashboard for new alerts.
- **Triage:** Verify if alerts are real threats (true positive) or false alarms (false positive).
- **Investigation:** If real, check logs, user activity, and devices.
- **Response:** Block IPs, disable accounts, isolate machines.
- **Documentation:** Write incident reports for future reference.

□ Example:

- Alert: "Multiple failed logins on a server."
- L1 Analyst: Checks if it's a real brute force attack or just a user typing the wrong password.

1.6 Key Responsibilities of a SOC Analyst (Freshers)

- Monitor SIEM (Security Information and Event Management) tools.
- Detect unusual activities.
- Analyze basic logs (Windows, Linux, network).
- Escalate suspicious cases to senior analysts.
- Document findings and create reports.

✓ End of Chapter 1 Summary

- Cybersecurity protects digital systems.
- SOC is the command center for detecting/responding to threats.
- SOC has different roles (L1, L2, L3, Manager).
- Freshers (L1) focus on monitoring, triage, and reporting.

Chapter 2: Basics of Networking (for SOC)

2.1 Why Networking is Important for SOC

- Most cyberattacks happen **over the network** (phishing emails, malware downloads, brute force logins, DDoS).
- SOC analysts investigate **network traffic, logs, and alerts** to find suspicious activity.
- Without networking knowledge, it's hard to understand **how attackers move through systems**.

2.2 OSI Model (The Foundation)

The **OSI (Open Systems Interconnection) Model** explains how data travels across a network in **7 layers**.

Layer	Name	Example	SOC Relevance
7	Application	HTTP, HTTPS, DNS, SMTP	Detect phishing, C2 traffic, malicious websites
6	Presentation	Encryption (SSL/TLS)	Identify SSL/TLS issues, weak ciphers
5	Session	NetBIOS, RPC	Session hijacking detection
4	Transport	TCP, UDP	Spot port scans, unusual connections
3	Network	IP, ICMP	Track attacker IPs, DoS attacks

2	Data Link	MAC Address, ARP	ARP spoofing detection
1	Physical	Cables, Wi-Fi signals	Rare for SOC, but DoS via jamming possible

❑ **SOC Tip:** Most alerts focus on **Layers 3, 4, and 7** (IP, TCP/UDP, HTTP/DNS).

2.3 TCP/IP Basics

The **TCP/IP model** (simpler version of OSI) has 4 layers:

Layer	Example Protocols	SOC Use Case
Application	HTTP, HTTPS, DNS, SMTP	Detect phishing, malicious domains
Transport	TCP, UDP	Identify brute force attempts
Internet	IP, ICMP	Track attacker IPs
Network Access	Ethernet, Wi-Fi	Spot unauthorized devices

❑ **Example:** A brute force attack shows as **many failed login attempts** over **TCP port 22 (SSH)**.

2.4 Common Network Devices (SOC Perspective)

Device	Role	SOC Logs to Monitor
Firewall	Blocks/Allows traffic	Blocked connections, denied ports
IDS/IPS	Detects/Prevents attacks	Alerts for exploits, malware traffic
Router	Routes traffic	Configuration changes, unusual routes
Switch	Connects devices	MAC flooding attempts
Proxy	Hides internal systems	Logs for URL filtering, malicious requests

❑ **SOC Tip:** Always check **firewall and proxy logs** first during investigations.

2.5 Important Protocols for SOC Analysts

Protocol	Port	SOC Concern	Attack Example
HTTP	80	Unencrypted web traffic	Malware download site
HTTPS	443	Encrypted traffic (harder to inspect)	Phishing site with SSL
DNS	53	Resolves domains to IPs	DNS tunneling for data theft
SMTP	25	Email transfer	Phishing, spam, malware delivery
FTP	21	File transfer	Anonymous login abuse
SSH	22	Secure remote login	Brute force login attempts
RDP	3389	Remote desktop	RDP brute force, ransomware

2.6 Real SOC Example

- ❑ **Alert:** High number of failed logins on port 22 (SSH).
 - L1 Analyst: Checks logs → sees 500 failed logins from IP in another country.
 - L2 Analyst: Confirms brute force attack.
 - Response: Block attacker IP at firewall + enforce strong password policy.

✓ End of Chapter 2 Summary

- Networking is the foundation of SOC investigations.
- OSI and TCP/IP help analysts understand where attacks occur.
- Key focus: **protocols (HTTP, DNS, SMTP, SSH, RDP)**.
- Logs from firewalls, IDS/IPS, and proxies are most important.

Chapter 3: Windows & Linux Fundamentals for SOC

- Every cyberattack leaves **traces inside the operating system**.
- SOC analysts use OS logs and commands to identify **who did what, when, and how**.

- Understanding Windows & Linux helps analysts separate **normal behavior** from **suspicious behavior**.

□ 3.2 Windows Fundamentals

3.2.1 Important Log Sources

Windows generates logs that are viewable in the **Event Viewer** (`eventvwr.msc`).

Log Type	Path in Event Viewer	What It Shows	SOC Use
Security Logs	Windows Logs → Security	Login attempts, account usage	Detect brute force, privilege misuse
System Logs	Windows Logs → System	OS and driver errors	Detect system or service crashes
Application Logs	Windows Logs → Application	App-level messages	Detect suspicious app behavior
PowerShell Logs	Applications and Services → Microsoft → Windows → PowerShell	PowerShell script executions	Detect malicious scripting
Task Scheduler Logs	Task Scheduler → Operational	Scheduled jobs	Detect persistence mechanisms

3.2.2 Common Windows Event IDs

Event ID	Description	SOC Use Case
4624	Successful login	Identify legitimate logins
4625	Failed login	Detect brute force attempts
4672	Admin privileges assigned	Privilege escalation
4688	New process created	Process monitoring, malware execution
4720	New user account created	Detect unauthorized account creation
1102	Audit logs cleared	Detect log tampering

3.2.3 Key Windows Commands for Investigation

Command	Purpose	Example SOC Use
whoami	Shows current user	Check privilege level
tasklist	Lists running processes	Detect unknown processes
netstat -ano	Shows active network connections	Spot suspicious IPs
wmic process list	Lists process info	Identify unusual child processes
systeminfo	System details	Identify OS version, hotfixes
Get-EventLog (PowerShell)	Read event logs	Search specific event IDs

3.3 Linux Fundamentals

Linux is widely used in servers and cybersecurity tools (SIEM, firewalls, etc.), so analysts must understand its basics.

3.3.1 Important Log Files

Log File	Path	Description	SOC Use Case
auth.log	/var/log/auth.log	Authentication logs	Detect SSH logins/brute force
secure	/var/log/secure	Security events	Track sudo or root access
syslog	/var/log/syslog	General system messages	Detect abnormal system behavior
messages	/var/log/messages	Kernel/system logs	Identify startup/shutdown events
bash_history	/home/user/.bash_history	User command history	Check suspicious commands

3.3.2 Key Linux Commands for SOC Analysts

Command	Purpose	Example SOC Use
who / w	See logged-in users	Detect unauthorized login
last	Show login history	Identify login anomalies
ps aux	View running processes	Detect suspicious processes
netstat - tulnp	Show open ports	Identify malicious connections
grep	Search inside files	Find keywords in logs
journalctl	View systemd logs	Central log viewing
chmod, chown	Change file permissions/ownership	Check privilege misuse

3.3.3 Example: Brute Force Attack in Linux Logs

- ❑ **Alert:** Multiple failed SSH logins detected.
- SOC checks /var/log/auth.log → sees repeated “Failed password” from same IP.
 - Confirms brute force attempt.
 - Response: Block attacker IP using firewall (iptables), enable fail2ban.

3.4 Windows vs Linux (SOC Comparison)

Aspect	Windows	Linux
Used For	Endpoints, user systems	Servers, network devices
Logs Location	Event Viewer	/var/log/ directory
Commands	CMD / PowerShell	Terminal / Shell
Common Attacks	Malware, RDP brute force	SSH brute force, privilege escalation
Monitoring Tools	Sysmon, Windows Defender	Auditd, Syslog, OSSEC

✓ End of Chapter 3 Summary

- Understand **Windows Event IDs** and **Linux log files** — they’re vital in investigations.
- Use system commands to validate alerts and spot anomalies.
- Both OS types require **log analysis and command-line skills** to identify threats.

Chapter 4: Security Tools (SIEM, EDR, XDR, IDS/IPS)

□ 4.1 Why Security Tools Matter in SOC

A SOC is only as effective as the tools it uses.
Each tool has a **specific role** — some collect logs, some detect malware, others block network attacks.
Together, they form the **SOC technology stack**.

□ 4.2 Key Security Tools Overview

Tool Type	Purpose	Common Examples
SIEM	Centralized log collection and correlation	Splunk, IBM QRadar, Azure Sentinel, ELK Stack
EDR	Endpoint-level detection & response	CrowdStrike, Defender for Endpoint
XDR	Extended detection across multiple sources	Palo Alto Cortex XDR, SentinelOne, Trend Micro Vision One
IDS/IPS	Network attack detection/prevention	Snort, Suricata, Palo Alto, Cisco Firepower
Firewall	Blocks/filters unwanted traffic	Fortinet, Check Point, Palo Alto, Sophos
Sandbox	Executes suspicious files safely	Cuckoo Sandbox, FireEye, ANY.RUN
Threat Intel Platform	Provides external threat data	MISP, VirusTotal, Anomali
Vulnerability Scanner	Detects software vulnerabilities	Nessus, OpenVAS, Qualys

□ 4.3 SIEM (Security Information and Event Management)

What It Does

- Collects **logs** from all systems (firewalls, endpoints, servers, etc.)
- **Correlates** them to identify suspicious patterns.
- Generates **alerts** for SOC analysts to investigate.

SOC Use Example

Alert: *“Multiple failed logins from the same IP followed by a successful login.”*

✓SOC checks SIEM → finds brute-force behavior → escalates to L2 for deeper investigation.

Key SIEM Functions

- Log collection & normalization
- Correlation rules
- Alerting & dashboards
- Threat hunting queries
- Reporting & compliance

□ 4.4 EDR (Endpoint Detection & Response)

What It Does

- Focuses on **endpoint protection** (laptops, desktops, servers).
- Monitors processes, registry, memory, and file behavior.
- Detects **malware, ransomware, suspicious scripts**.

SOC Use Example

Alert: *“Suspicious PowerShell script executed by Word.exe.”*

✓EDR shows process tree → Word → PowerShell → network connection → possible malware download.

Key Features

- Real-time endpoint monitoring
- Process and file analysis
- Isolation of infected devices
- Threat containment (kill process, quarantine file)

□ 4.5 XDR (Extended Detection & Response)

What It Does

- Extends beyond endpoints to include **network, cloud, email, and identity**.
- Correlates data across multiple sources for **complete attack visibility**.
- Uses AI/ML for threat detection.

SOC Use Example

Alert: *“Phishing email → user clicked → PowerShell script launched → connection to malicious IP → lateral movement detected.”*

✓XDR connects all these events automatically → one consolidated alert → faster response.

Key Advantages

- Unified visibility
- Cross-layer detection
- Automated investigation & response

□♂ 4.6 IDS vs IPS

Feature	IDS (Intrusion Detection System)	IPS (Intrusion Prevention System)
Purpose	Detects malicious activity	Detects and blocks malicious activity
Action	Monitors and alerts	Monitors, alerts, and blocks
Placement	Out-of-band (passive)	Inline (active)
SOC Use	Detects port scans, exploits	Blocks DDoS or brute force traffic

Example Tools	Snort, Suricata	Cisco Firepower, Palo Alto Threat Prevention
----------------------	-----------------	--

□ 4.7 Firewalls

- Firewalls control **inbound and outbound network traffic** based on security rules.
- They act as the **first line of defense**.

Types:

- **Network Firewall** – Filters IPs, ports, protocols.
- **Web Application Firewall (WAF)** – Protects web apps from SQL injection, XSS.
- **Next-Gen Firewall (NGFW)** – Includes deep packet inspection, intrusion prevention, app control.

SOC Tip: Review firewall **deny logs** to identify attempted intrusions.

□ 4.8 Sandbox Analysis

- Used to **analyze suspicious files** in a controlled environment.
- Helps determine if a file is **malicious without risking real systems**.

Example:

A suspicious attachment is sent via email → Uploaded to sandbox → Executes → Found to download malware → SOC blocks sender domain.

□ 4.9 Threat Intelligence Platforms (TIPs)

- Collect data about **known malicious IPs, domains, hashes**.
- Used to **enrich SOC alerts** with context.
- Often integrated into SIEM or XDR for automated enrichment.

Example: VirusTotal, MISP, Anomali, IBM X-Force Exchange.

□ 4.10 Vulnerability Scanners

- Identify software and configuration weaknesses.
- Used by SOC to **find and report systems at risk**.

Example: Nessus scan shows outdated Apache version → SOC informs patch team to update before attackers exploit it.

□ 4.11 SIEM vs EDR vs XDR (Quick Comparison)

Feature	SIEM	EDR	XDR
Scope	Logs from all systems	Endpoint activity	All layers (endpoint, network, email, cloud)
Data Source	Logs	Endpoint telemetry	Multiple integrated sources
Response	Manual (by analyst)	Automated on endpoint	Automated across environment
Focus	Detection & correlation	Endpoint protection	Unified detection & response
Example Tool	Splunk, QRadar	CrowdStrike	Cortex XDR, SentinelOne XDR

✓ End of Chapter 4 Summary

- SOC tools are your **eyes and ears** — they help detect and respond to threats quickly.
- **SIEM** = log analysis, **EDR** = endpoint protection, **XDR** = full ecosystem visibility.
- IDS/IPS, firewalls, sandbox, and threat intel tools enhance detection accuracy.

Chapter 5: SOC Key Concepts

□ 5.1 What is a SOC?

A **Security Operations Center (SOC)** is a team and facility that continuously monitors, detects, investigates, and responds to security incidents within an organization.

Goal: Protect systems, networks, and data from cyber threats in real time.

□ 5.2 Key SOC Functions

- **Monitoring:** Watch logs, alerts, and network traffic.
- **Detection:** Identify abnormal or suspicious activities.
- **Investigation:** Analyze root cause and impact.
- **Response:** Contain, eradicate, and recover from incidents.
- **Reporting:** Document findings and suggest improvements.

□ 5.3 Alert Triage

The **first step** in incident handling — reviewing and prioritizing alerts.

Steps:

1. **Validate** – Check if the alert is real.
2. **Classify** – Type of threat (malware, phishing, policy violation).
3. **Prioritize** – Based on severity and business impact.
4. **Escalate** – Send to L2/L3 if needed.

Example:

“PowerShell launched from Word.exe” → Suspicious → Analyst validates via EDR → True positive → Escalate.

□ 5.4 Incident Lifecycle (NIST Model)

Stage	Description	Example
1. Preparation	Tools, processes, policies ready	SIEM, playbooks
2. Detection & Analysis	Identify incidents	Malware detected on endpoint
3. Containment	Stop the spread	Isolate device
4. Eradication	Remove root cause	Delete malware, patch
5. Recovery	Restore systems	Reconnect to network
6. Lessons Learned	Report, improve defenses	Post-incident review

□ 5.5 Indicators of Compromise (IOCs)

Clues that a system may be compromised.

Types:

- **File Hashes** (e.g., MD5, SHA256)
- **IP Addresses / Domains**
- **Registry Changes**
- **Suspicious Processes or Filenames**

Example:

IOC found: IP 185.193.127.15 — listed in threat intel as C2 server → Investigation started.

□ 5.6 MITRE ATT&CK Framework

A global knowledge base of **adversary tactics, techniques, and procedures (TTPs)** used by attackers.

Common Tactics:

- **Initial Access** – Phishing, drive-by compromise

- **Execution** – PowerShell, scripts
- **Persistence** – Registry run keys, services
- **Privilege Escalation** – Exploiting vulnerabilities
- **Defense Evasion** – Obfuscation, disabling security tools
- **Exfiltration** – Data theft

Example Mapping:

Alert: Word launches PowerShell → **Tactic:** Execution → **Technique:** T1059 (Command & Scripting Interpreter).

□ 5.7 True Positive vs False Positive

Type	Meaning	Example
True Positive (TP)	Real threat detected correctly	Malware blocked on endpoint
False Positive (FP)	Benign activity flagged as threat	Admin PowerShell script triggers alert
True Negative (TN)	No threat, no alert	Normal login activity
False Negative (FN)	Threat missed	Undetected phishing email

SOC Goal: Minimize **false positives** and **false negatives** for better efficiency.

□ 5.8 Common SOC Alert Examples

Alert Type	Description	MITRE Mapping
Phishing Email	Malicious email with link/attachment	Initial Access (T1566)
Malware Execution	File download or PowerShell execution	Execution (T1059)
Privilege Escalation	User gains admin rights	Privilege Escalation (T1068)
Lateral Movement	Connection to another host	Lateral Movement (T1021)
Data Exfiltration	Large data transfer to external IP	Exfiltration (T1041)

□ 5.9 Escalation Matrix (Simplified)

- **L1 (Tier 1):** Initial triage & validation.
- **L2 (Tier 2):** Deep investigation & correlation.
- **L3 (Tier 3):** Threat hunting, forensics, advanced analysis.
- **Incident Response Team:** Handles containment & recovery.

□ 5.10 Playbooks

Predefined **step-by-step procedures** to handle common alerts (e.g., phishing, malware, ransomware).

They help analysts act **quickly and consistently**.

Example: *Phishing Playbook:* Verify → Quarantine → Block sender → Reset user password → Report to TI team.

✓ End of Chapter 5 Summary

- SOC = Detect + Respond + Protect.
- MITRE ATT&CK helps analysts understand attacker behavior.
- Triage and escalation keep response organized.
- True/False positive understanding improves alert accuracy.

Chapter 6: Common Cyber Threats

Definition:

Malware (malicious software) is any program or code designed to **harm, exploit, or gain unauthorized access** to a system.

□ Types of Malware

Type	Description	Example / SOC Alert
Virus	Attaches itself to legitimate programs and spreads when executed.	"Suspicious file modification in system32 folder."
Worm	Self-replicating malware that spreads over the network without user action.	"Multiple hosts showing same suspicious file hash."
Trojan	Disguised as legitimate software to trick users into installing it.	"User executed file 'invoice.pdf.exe' from email."
Ransomware	Encrypts files and demands ransom for decryption key.	"Files renamed with .locked extension; ransom note detected."

□ 6.2 Phishing & Social Engineering

Definition:

Phishing is a **social engineering technique** where attackers trick users into revealing sensitive information or downloading malware via **fake emails, links, or attachments**.

□ Common Types

Type	Description	Example
Email Phishing	Fake email asking to click a link or reset password.	"Your account is locked – click here to verify."
Spear Phishing	Targeted phishing aimed at specific users.	Fake HR email to finance employee.
Smishing	Phishing via SMS.	"Your bank account is frozen. Tap link."
Vishing	Voice-based phishing.	"Caller posing as IT support asking for credentials."

SOC Example:

Alert: Email from external domain with suspicious attachment (macro-enabled Word file).

Investigation: Sandbox execution confirms connection to malicious IP.

Mitigation:

- User awareness training.
- Email filters and sandboxing.
- Block malicious domains and attachments.

□ 6.3 Brute Force & Credential Stuffing

□ Brute Force Attack

Attackers **try multiple username-password combinations** until they succeed.

Usually detected by **multiple failed login attempts** followed by a success.

SOC Example:

SIEM alert: 20 failed logins → 1 successful login from same IP within 5 minutes.

Prevention:

- Enforce strong passwords.
- Account lockout policy.
- Use multi-factor authentication (MFA).

□ Credential Stuffing

Attackers use **stolen username-password pairs** (from data breaches) to gain access to multiple systems where users reuse passwords.

SOC Example:

Logins from multiple countries using same credentials — indicates automated credential testing.

Prevention:

- Use unique passwords per site.
- Monitor for credential reuse.
- Implement MFA and rate-limiting.

❑ **6.4 Insider Threats**

Definition:

An insider threat comes from **employees, contractors, or partners** who misuse authorized access intentionally or accidentally.

❑ **Types of Insider Threats**

Type	Description	Example
Malicious Insider	Intentional data theft or sabotage.	Employee exfiltrates client data before resignation.
Negligent Insider	Accidental actions causing risk.	User clicks phishing link or misconfigures access.
Compromised Insider	Account taken over by an attacker.	Attacker uses employee’s credentials for lateral movement.

SOC Detection Indicators:

- Unusual data downloads or email attachments.
- Logins outside business hours.
- Data transfer to unauthorized cloud storage.

Mitigation:

- Behavior analytics (UEBA tools).
- Least privilege access control.
- Continuous activity monitoring.

✔ **End of Chapter 6 Summary**

Threat Type	Goal	SOC Detection Method
Malware	Infect or damage systems	EDR/XDR alerts, hash comparison

Phishing	Steal credentials or deliver malware	Email gateway, sandbox analysis
Brute Force / Credential Stuffing	Gain unauthorized access	Login failure patterns in SIEM
Insider Threats	Data theft or misuse	UEBA, DLP, abnormal behavior alerts

Chapter 7: Hands-On for Freshers

Goal:

A SOC analyst uses a **SIEM (Security Information and Event Management)** tool to collect, correlate, and analyze logs from various systems (firewalls, endpoints, servers, email, etc.).

□ Step-by-Step Log Analysis Approach

1. Identify the Alert Source

- Example: "Multiple failed login attempts" from the Windows event log.
- Note the **device**, **IP**, **user**, and **timestamp**.

2. Gather Context

- Check related logs for the same user/IP.
- Correlate with firewall or endpoint data.

3. Validate the Alert

- Was it triggered by a **real attack** or **normal user behavior**?
- Compare with threat intel (IP/domain reputation).

4. Check for Related IOCs

- Look up suspicious hashes, IPs, or URLs on VirusTotal, AbuseIPDB, etc.

5. Determine the Severity

- High:** Malware, data exfiltration, lateral movement.
- Medium:** Multiple failed logins, privilege escalation attempts.
- Low:** Policy violation or misconfiguration.

6. Document Findings

- Summarize event details, actions taken, and recommended next steps.

7. Escalate if Needed

- Send to **L2 or Incident Response team** if it's a confirmed threat.

□ Common Log Sources in SIEM

Log Source	Example	Use in SOC
Windows Event Logs	User logon, process creation	Detect brute force, privilege escalation
Firewall Logs	IP allow/deny, port access	Detect unauthorized access
Proxy/Web Logs	Website requests	Detect phishing or malware download
EDR/XDR Logs	Process tree, file activity	Detect malware execution
Email Gateway Logs	Sender, attachments	Detect phishing attempts

□ 7.2 Step-by-Step: Handling a Phishing Alert

Scenario:

A user reports a suspicious email received from an unknown sender with a “Payment Invoice.pdf” attachment.

□ Step-by-Step Process

1. Collect Basic Details

- Sender address, subject line, and timestamp.
- User who received it and if they clicked/downloaded anything.

2. Check Email Headers

- Look for mismatched domains (e.g., @microsoft-support.com vs legit@microsoft.com).

3. Inspect the Attachment or Link

- Upload to **sandbox** (Cuckoo, ANY.RUN, etc.) to analyze safely.
- If it's a link, check domain reputation (VirusTotal / URLscan).

4. Search SIEM for Related Activity

- Query for emails with same subject/sender to see if others received it.
- Check for any **HTTP/HTTPS requests** to suspicious URLs.

5. Containment

- Quarantine the email (via email security gateway).
- Block malicious domain/IP in the firewall or proxy.

6. Eradication & Recovery

- a. If user clicked link or downloaded file, **isolate endpoint** via EDR.
- b. Perform malware scan and remove any infections.

7. Post-Incident Action

- a. Force **password reset** for impacted users.
- b. Update SIEM rules / blocklists for new IOCs.
- c. Educate users to recognize similar phishing attempts.

MITRE Mapping:

Initial Access → Phishing (T1566)

□ 7.3 Step-by-Step: Investigating a Brute Force Attempt

Scenario:

SIEM alert: "Multiple failed logins detected on Windows Server from IP 203.0.113.15."

□ Step-by-Step Process

1. Identify the Source and Target

- a. Source IP: 203.0.113.15
- b. Target: DC01.corp.local
- c. Account: admin

2. Correlate Event IDs (Windows Example)

- a. **4625**: Failed logon attempts.
- b. **4624**: Successful logon.
- c. If several 4625s followed by one 4624 → possible brute force success.

3. Check the Frequency

- a. Count how many failed attempts occurred and in what timeframe.
- b. Example: 50 attempts in 3 minutes = likely automated attack.

4. Enrich with Threat Intelligence

- a. Look up source IP in VirusTotal or AbuseIPDB.
- b. If reputation = malicious → confirm external attack.

5. Containment

- a. Block source IP in firewall.
- b. Temporarily disable or lock compromised account.

6. Eradication & Recovery

- a. Reset affected account passwords.
- b. Review privilege access and audit logs.

7. Post-Incident Steps

- a. Implement **account lockout policy**.
- b. Enable **MFA** (multi-factor authentication).
- c. Monitor for repeated login attempts.

MITRE Mapping:

Tactic: Credential Access → Technique: Brute Force (T1110)

✓ End of Chapter 7 Summary

Scenario	Key Action	SOC Tool
Log Analysis	Validate, correlate, enrich, escalate	SIEM (Splunk, QRadar, Sentinel)
Phishing Alert	Quarantine, isolate, block domain/IP	Email Gateway, Sandbox, EDR
Brute Force Attempt	Investigate login logs, block IP, enforce MFA	SIEM, Firewall, AD Logs

Chapter 8: Vulnerability & Threat Management

□ 8.1 What is a Vulnerability?

A **vulnerability** is a weakness or flaw in a system, software, or configuration that an attacker can exploit to gain unauthorized access or perform malicious actions.

Example:

- Unpatched Windows system → exploited by ransomware.
- Weak admin password → used for brute-force login.

In short:

Vulnerability = Weakness

Threat = Something that can exploit the weakness

Risk = The potential impact if exploited

□ 8.2 What is CVE?

CVE (Common Vulnerabilities and Exposures)

- A **unique identifier** for a publicly known cybersecurity vulnerability.
- Managed by **MITRE Corporation**.
- Helps security teams track and discuss specific vulnerabilities.

Example:

- CVE-2021-44228 → Log4j Remote Code Execution vulnerability.
- CVE-2017-0144 → EternalBlue vulnerability used in WannaCry.

CVE Format:

CVE-[Year]-[Number]

e.g., CVE-2025-12345

In interview terms:

CVE is like a “serial number” for a known security vulnerability.

□ 8.3 What is CVSS?

CVSS (Common Vulnerability Scoring System)

- A **numerical score (0–10)** that shows how severe a vulnerability is.
- Created by **FIRST.org** to standardize risk measurement.

Score Range	Severity	Meaning
0.0	None	No impact
0.1–3.9	Low	Minor exposure
4.0–6.9	Medium	Limited exploitation potential
7.0–8.9	High	Serious security issue
9.0–10.0	Critical	Easily exploitable, severe impact

Example:

- CVE-2021-44228 (Log4j) → **CVSS 10.0** (Critical)

- CVE-2020-0796 (SMBGhost) → **CVSS 8.1** (High)

In simple terms:

CVSS tells you *how dangerous* a vulnerability is.

□ 8.4 Vulnerability Scanning Tools

SOC and vulnerability management teams use automated scanners to **detect vulnerabilities** in systems and applications.

□ Common Tools:

Tool	Type	Description / Usage
Nessus	Commercial	Most widely used vulnerability scanner; detects OS, network, and application flaws.
OpenVAS (Greenbone)	Open Source	Free and community-driven alternative to Nessus.
QualysGuard	Cloud-based	Enterprise-grade continuous vulnerability management tool.
Rapid7 InsightVM (formerly Nexpose)	Commercial	Integrates with SIEM and ticketing tools.
Microsoft Defender for Endpoint	Built-in	Detects OS vulnerabilities and missing patches.

Basic Workflow:

1. Scan target systems (servers, endpoints, network devices).
2. Identify vulnerabilities by matching with CVE database.
3. Prioritize based on CVSS score.
4. Generate a report and assign remediation tasks.

In SOC context:

Analysts review vulnerability reports and check if any critical CVEs are being exploited in the wild.

□ 8.5 Patch Management Basics

Patch Management is the process of applying updates to fix vulnerabilities and improve software performance.

□ Steps in Patch Management:

1. **Identify**
 - a. Collect system/software inventory.
 - b. Match with known CVEs.
2. **Evaluate**
 - a. Assess risk using CVSS and business impact.
 - b. Prioritize critical systems (servers, endpoints, firewalls).
3. **Test**
 - a. Verify patch compatibility in a test environment.
4. **Deploy**
 - a. Apply patches during maintenance windows.
 - b. Automate using WSUS, SCCM, or Intune.
5. **Verify & Monitor**
 - a. Re-scan after patching to ensure vulnerability is fixed.
 - b. Document the update.

□ Example Interview Scenario:

Q: What would you do if you find a critical CVE on a production server?

A:

1. Confirm the vulnerability using a scanner.
2. Check CVSS score and exploit availability.
3. Coordinate with IT team for patch testing.
4. Apply the patch or workaround in a controlled manner.
5. Validate post-patch using re-scan or SIEM monitoring.

□ Summary

Term	Meaning	Example
CVE	Public ID for vulnerability	CVE-2021-44228 (Log4j)

CVSS	Severity scoring system	CVSS 10.0 = Critical
Vulnerability Scanner	Tool to detect weaknesses	Nessus, OpenVAS
Patch Management	Process of fixing vulnerabilities	WSUS, SCCM

✓ End of Chapter 8 Summary

Key takeaway for SOC analysts:

Understanding CVE, CVSS, scanning tools, and patch management helps you **prioritize and mitigate risks** before attackers exploit them.

Chapter 9: Reporting & Documentation

□ 9.1 Importance of Reporting in SOC

In a SOC, *technical findings are valuable only when clearly communicated.*

Good reporting helps:

- Track the **incident timeline and response**.
- Communicate with **management and stakeholders**.
- Build a **knowledge base** for future incidents.

In simple words:

If you didn't document it — it didn't happen.

□ 9.2 How to Write an Incident Report

A professional incident report should answer **What, When, Who, Where, How, and What Next**.

□ Standard Structure

Section	Purpose	Example / Tip
1. Title & Summary	Short description of the incident	"Phishing Email Campaign Detected – HR Department"

2. Detection Time	When was the alert generated / detected	"Detected on 27 Oct 2025 at 09:35 IST via Microsoft Defender"
3. Impacted Systems / Users	Who or what was affected	"User: john.doe@corp.com ; Host: ALTLAPMUM02"
4. Incident Description	What happened (brief narrative)	"A suspicious email containing a malicious PDF attachment was reported by a user. Investigation confirmed phishing."
5. Indicators of Compromise (IOCs)	IPs, URLs, hashes, email addresses	"URL: hxxp://pay-invoice[.]info; SHA256: abcd1234..."
6. Investigation Summary	Steps taken to confirm the alert	"Analyzed headers, sandboxed attachment, correlated with SIEM logs."
7. Containment Actions	Immediate steps to stop impact	"Quarantined email and isolated affected endpoint."
8. Eradication & Recovery	How the threat was removed	"Deleted malicious file, performed AV scan, reset credentials."
9. Lessons Learned / Recommendations	Prevent recurrence	"Implement stricter email filtering and user awareness training."
10. Closure Details	Final remarks & validation	"Incident resolved on 28 Oct 2025 – Verified via post-check."

□ Tips for Effective Reports

- Keep **language simple and factual** — avoid jargon.
- Use **timestamps** for every key step (helps in root cause analysis).
- Avoid assumptions — state evidence only.
- Use screenshots or log snippets where helpful.
- End with **clear next steps** or **recommendations**.

□ 9.3 Communicating with Managers / Non-Technical Teams

SOC analysts often need to brief **non-technical audiences** (like management or HR). Focus on **impact, not technical details**.

□ Example Comparison

Technical Explanation (Don't Say)	Business Explanation (Do Say)
"We detected CVE-2021-44228 exploitation via port 8080."	"A known vulnerability in our web application was exploited, allowing potential data access."
"SIEM correlated multiple T1059 PowerShell executions."	"We found unauthorized script activity that could indicate system tampering."
"We blocked IP 185.123.45.9 in the firewall."	"We blocked a malicious external connection to protect systems."

□ Best Practices

- Keep it **brief** (2–3 sentences per point).
- Focus on **impact, action taken, and current status**.
- Avoid tool names unless necessary.
- Always end with a **risk statement**:

"No data loss detected; systems remain operational."

□ 9.4 Best Practices in Escalation

When an alert looks suspicious or beyond your level (e.g., confirmed malware outbreak), **escalate it properly** to the next team (L2 / Incident Response).

□ Escalation Steps

1. **Verify Alert Validity**
 - a. Avoid false positives. Double-check with logs, threat intel, and context.
2. **Gather Evidence**
 - a. Include host name, IP, user, process name, and timestamps.
 - b. Attach screenshots or SIEM snippets if available.
3. **Classify Severity**

- a. Example:
 - i. Low → Policy violation
 - ii. Medium → Suspicious activity
 - iii. High → Confirmed malicious activity

4. Notify Correct Team

- a. Example:
 - i. L2 SOC → for deeper forensic analysis
 - ii. IT / SysAdmin → for isolation or patching
 - iii. Incident Response → for confirmed breach

5. Use Clear Subject Lines

- a. ✓ *Example:* “[High] Malware Infection on HR-LAPTOP-23 – Immediate Action Needed”
- b. ✗ *Avoid:* “Suspicious file found”

6. Follow Escalation Matrix

- a. Each SOC has a predefined matrix (who to inform at which severity).

7. Track Until Closure

- a. Always follow up and update incident status in ticketing tool.

❑ 9.5 Common Mistakes to Avoid

- ❑ Overuse of technical jargon — non-tech managers may miss the key point.
- ❑ Ignoring timestamps — creates confusion during RCA (Root Cause Analysis).
- ❑ Escalating without enough evidence — wastes senior analysts’ time.
- ❑ Not updating ticket status — leads to poor audit trail.

❑ Summary

Aspect	Key Point
Incident Report	Document “What happened, When, Who, How, and Resolution.”
Communication	Simplify for management — focus on impact, not tools.
Escalation	Verify, gather evidence, follow escalation path, and track closure.
Golden Rule	Clear, factual, and concise communication = Effective SOC.

✓ End of Chapter 9 Summary

Remember: A well-documented and clearly communicated incident is half-resolved — it builds trust, traceability, and efficiency in every SOC operation.

Chapter 10: Career Growth & Interview Prep

□ 10.1 SOC Analyst Career Path

A SOC career usually begins with **monitoring and triaging alerts**, then expands into deeper **incident response, threat hunting**, and **engineering roles**.

□ Typical Career Progression

Role	Ex per ien ce	Key Responsibilities
□ L1 SOC Analyst (Fresher / Entry Level)	0–1 year	Monitor SIEM alerts, triage events, identify false positives, escalate true positives.
□ L2 SOC Analyst	1–3 years	Perform in-depth investigation, correlation, and incident response. Work on phishing, malware, and lateral movement cases.
□♂ Threat Hunter	2–4 years	Proactively search for hidden or undetected threats using logs, EDR, and threat intel. Create detection rules.
□ Incident Responder	3–5 years	Lead containment, eradication, and recovery after confirmed security incidents. Perform forensic analysis.
□□ Security Engineer / Architect	4–7 years	Design, implement, and maintain SOC tools (SIEM, EDR, XDR). Improve automation and playbooks.

❑ SOC Manager / Security Consultant	7+ years	Manage SOC operations, team strategy, and client communication. Handle compliance and risk metrics.
--	----------	---

❑ 10.2 Common SOC Interview Questions (with Answers)

❑ Basic Questions

Question	Answer (Short & Interview-Ready)
What is a SOC?	A Security Operations Center (SOC) monitors and defends an organization's systems 24×7 against cyber threats.
Difference between SIEM, EDR, and XDR?	SIEM = log analysis; EDR = endpoint protection; XDR = integrates data from multiple sources (network, endpoint, cloud).
What is the CIA Triad?	Confidentiality, Integrity, Availability — the core of information security.
What is a false positive?	A benign event incorrectly flagged as malicious.
What are IOCs?	Indicators of Compromise — forensic clues like IPs, hashes, or domains that indicate a breach.

❑ Intermediate Questions

Question	Answer (Brief & Practical)
What steps do you take when analyzing an alert?	1❑ Validate the alert → 2❑ Correlate logs → 3❑ Check IOCs → 4❑ Classify severity → 5❑ Document and escalate.
How do you investigate a phishing email?	Check sender, subject, links, attachments → sandbox file → analyze headers → correlate in SIEM → isolate user if needed.
What's the difference between Threat, Vulnerability, and Risk?	Threat = potential danger, Vulnerability = weakness, Risk = impact if threat exploits vulnerability.
What are common Windows Event IDs?	4624 (Logon), 4625 (Failed Logon), 4688 (Process Creation), 4720 (User Creation).
What is MITRE ATT&CK used for?	To map attacker behaviors and understand techniques/tactics used in cyber attacks.

❑ Advanced / Scenario-Based

Question	Example Answer
How do you detect brute force in SIEM?	Look for multiple failed logins (Event ID 4625) followed by a successful one (4624) in short time from the same IP.
What would you do if you find a critical CVE in production?	Validate vulnerability → check exploit availability → coordinate patch testing → deploy fix → verify via re-scan.
Describe an incident you handled (if fresher)?	“During a lab simulation, I analyzed a phishing email with a malicious attachment, isolated the endpoint, and updated IOCs in SIEM.”
How do you reduce false positives?	Tune SIEM rules, whitelist known processes, and add context-based filters.
What is Threat Hunting?	A proactive approach to search for threats that bypass traditional security tools.

❑ 10.3 Certification Roadmap for SOC Analysts

Certifications help validate your skills and open doors for promotions or better roles.

❑ Recommended Roadmap (Beginner → Advanced)

Level	Certification	Focus Area
❑ Beginner	✓ <i>CompTIA Security+</i>	Core cybersecurity concepts, risk management, and network defense.
	✓ <i>Microsoft SC-200 (Security Operations Analyst)</i>	Hands-on SIEM (Sentinel) and XDR monitoring.
	✓ <i>Splunk Core Certified User / Power User</i>	SIEM searches, dashboards, and alerts.
❑ Intermediate	✓ <i>EC-Council CEH (Certified Ethical Hacker)</i>	Attack techniques and countermeasures.
	✓ <i>Blue Team Level 1 (BTL1)</i>	SOC operations, analysis, and detection.
	✓ <i>CySA+ (CompTIA Cybersecurity Analyst)</i>	Threat detection and incident response.

❑ Advanced	✓ <i>GCIA / GCIH (SANS)</i>	Intrusion analysis and incident handling.
	✓ <i>OSCP / CHFI / CCSP</i>	Red teaming, forensics, or cloud security.

❑ 10.4 Continuous Learning & Skill-Building

To stay relevant in cybersecurity, follow a “**Learn** → **Practice** → **Share**” routine.

❑ Practice Platforms

- **TryHackMe / BlueTeamLabs** – Hands-on SOC & IR labs.
- **RangeForce / CyberDefenders** – Real-world detection scenarios.
- **Splunk Boss of the SOC (BOTS)** – SIEM challenge competition.

❑ Stay Updated

- Follow **CVE**, **CISA**, **MITRE**, and **BleepingComputer** updates.
- Read **threat intel reports** from Palo Alto, Cisco Talos, and Mandiant.

❑ Networking

- Join **LinkedIn cybersecurity groups**, **Reddit r/blueteamsec**, or **Discord SOC communities**.
- Share knowledge — explaining concepts improves retention.

❑ Summary

Topic	Key Takeaway
Career Path	Start as SOC Analyst → grow into Threat Hunter, Incident Responder, or Security Engineer.
Interview Prep	Focus on SIEM alerts, incident lifecycle, and key tools.
Certifications	Begin with <i>Security+ / SC-200</i> , move to <i>CEH / CySA+</i> , then <i>GCIH / OSCP</i> .
Skill Growth	Practice, learn from incidents, and stay updated with latest threats.

